

SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE NAME: Ethical Hacking COURSE CODE: ITA14

COURSE OUTCOME COVERED

CO4: *Implement network security testing methods by performing web server attacks, analyzing web application vulnerabilities, and assessing wireless network security using Kali Linux.*

QUESTIONS: 01 Total Marks:100

Annexure A

VULNERABILITY ASSESSMENT REPORT

Code of Conduct:

I Y.HEMA SAI LAHARI(192311446)(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: Y.HEMA SAI LAHAERI

S. No	Assessment Criterion	Excellent	Good	Satisfactory	Needs Improvement	Marks
1	Incident Background and Technical Understanding (20)	Clearly explains the incident, timeline, affected organization, threat actor, wireless technology, and attack context.	Explains most incident details with minor omissions.	Provides a basic incident summary but lacks technical depth.	Incident description is inaccurate, incomplete, or unclear.	
2	Identification of Wireless Vulnerabilities (20)	Accurately identifies vulnerabilities related to wireless standards,	Identifies most major vulnerabilities with reasonable	Identifies only basic or obvious vulnerabilities.	Fails to identify important vulnerabilities or	

		encryption, authentication, access points, configuration, and network architecture.	explanation.		provides incorrect findings.	
3	Risk, Impact, and Root-Cause Analysis(20)	Provides a detailed analysis of attack vectors, root causes, affected assets, likelihood, and operational, financial, privacy, legal, and reputational impacts.	Provides a good risk and impact analysis with minor gaps.	Discusses general risks and impacts without sufficient justification.	Risk analysis is weak, irrelevant, or unsupported.	
4	Security Recommendations and Mitigation Measures(20)	Proposes practical and well justified controls involving secure authentication, encryption, segmentation, monitoring, access control, policies, and user awareness.	Recommends appropriate controls with minor omissions.	Provides basic recommendations with limited technical detail.	Recommendations are impractical, incomplete, or unrelated to the identified risks.	
5	Report Quality, Evidence, and	Report is well-structured, professionally written,	Report is clear and organized with	Report is understandable but	Report is poorly organized, unsupported, or contains major	

	Presentation(20)	supported by reliable references, diagrams, tables, and a clear risk-rating summary.	suitable evidence and references.	lacks organization, evidence, or proper referencing.	presentation errors.	
					Total	

Annexure A

1. TJX Companies Wireless Network Breach, 2005–2007

TJX Companies experienced a major payment-card data breach after attackers obtained unauthorized wireless access to its retail network. Investigations found that TJX had used WEP while transitioning to WPA and had not implemented adequate controls to restrict wireless access. The incident demonstrated the risks of obsolete encryption, inadequate monitoring, weak network segmentation, and insecure transmission of sensitive data.

Assignment Question: Prepare a Vulnerability Assessment Report examining the wireless encryption, authentication, network segmentation, monitoring, and payment-data protection weaknesses that contributed to the TJX incident. Recommend how WPA2/WPA3, enterprise authentication, rogue-access-point detection, and PCI DSS controls could have reduced the risk.

2. Lowe's Wireless Network Intrusion, 2003

In 2003, attackers compromised the wireless network of a Lowe's retail store in Southfield, Michigan. The compromised wireless connection provided access to the company's central systems and other retail locations. The attackers attempted to install software intended to capture customers' credit-card information.

Assignment Question: Prepare a Vulnerability Assessment Report identifying the weaknesses that allowed a local wireless compromise to create access to a nationwide corporate network. Assess authentication, wireless isolation, firewall controls, point-of-sale segmentation, intrusion detection, and centralized access management.

3. Firesheep and Public Wi-Fi Session Hijacking, 2010

The Firesheep browser extension demonstrated how attackers connected to the same open wireless network could capture unencrypted session cookies and impersonate

authenticated users. The event highlighted the danger of websites encrypting only the login page while transmitting later session information without full HTTPS protection.

Assignment Question: Prepare a Vulnerability Assessment Report for a public Wi-Fi provider affected by Firesheep-style session hijacking. Assess open-network authentication, session cookie protection, HTTPS enforcement, HSTS, VPN use, wireless client isolation, and user security awareness.

4. DarkHotel Attacks Through Hotel Wi-Fi Networks

The DarkHotel campaign targeted business executives and government officials using compromised hotel networks. Selected guests connecting to hotel Wi-Fi were presented with fraudulent software-update prompts that delivered malware. The campaign demonstrated the risks associated with third-party Wi-Fi management, captive portals, insecure update mechanisms, and insufficient guest-network monitoring.

Assignment Question: Prepare a Vulnerability Assessment Report for the affected hotel environment. Examine guest authentication, captive-portal security, DNS integrity, network segmentation, third-party access, digital-signature verification, malware detection, and monitoring of privileged hotel-network systems.

5. Marriott Wi-Fi Deauthentication Incident, 2014

The United States Federal Communications Commission investigated Marriott after equipment was used to send Wi-Fi deauthentication messages that prevented guests from using their personal hotspots. Marriott agreed to pay a civil penalty of \$600,000. The incident showed how unprotected wireless management frames could be misused to disconnect legitimate users.

Assignment Question: Prepare a Vulnerability Assessment Report analysing the misuse of IEEE 802.11 deauthentication frames. Discuss availability risks, wireless interference, Protected Management Frames, WPA3 requirements, wireless intrusion detection, acceptable use policies, and legal consequences.

6. Fake Wi-Fi Networks at the Republican National Convention, 2016

During the 2016 Republican National Convention, a security experiment established fake open wireless networks near the event venue. Approximately 1,200 users connected within one day, and the experiment demonstrated how easily users could trust unknown network names and expose device or identity information.

Assignment Question: Prepare a Vulnerability Assessment Report evaluating the risks created by open Wi-Fi and fake access points at large public events. Assess SSID trust, automatic reconnection, captive-portal authentication, evil-twin detection, certificate validation, VPN enforcement, and participant-awareness controls.

7. Wi-Fi Attacks Against Anti-Doping Officials, 2016

According to a United States Department of Justice indictment, close-access teams targeted Wi-Fi networks used by anti-doping officials during events in Rio de Janeiro and Lausanne. Hotel Wi-Fi access was allegedly used to compromise credentials and obtain unauthorized access to sensitive anti-doping and medical information.

Assignment Question: Prepare a Vulnerability Assessment Report for an international sporting organization whose officials frequently use hotel and event Wi-Fi. Evaluate public network authentication, credential protection, multifactor authentication, device certificates, endpoint security, VPN configuration, travel-security policies, and protection of medical information.

8. Attempted OPCW Wi-Fi Intrusion, 2018

In April 2018, Dutch authorities disrupted an attempted close-access cyber operation against the Organisation for the Prohibition of Chemical Weapons in The Hague. Equipment intended for a Wi-Fi compromise was found in a vehicle parked near the organization's premises.

Assignment Question: Prepare a Vulnerability Assessment Report for the OPCW wireless environment. Assess radio-frequency exposure outside the physical perimeter, enterprise Wi-Fi authentication, 802.1X, EAP certificate validation, rogue-device detection, wireless intrusion prevention, physical surveillance, and network-access control.

9. Australian Airport and In-Flight Evil-Twin Case, 2024

The Australian Federal Police charged a man who allegedly established fake free Wi-Fi access points that imitated legitimate networks at airports and other locations. The alleged purpose was to capture personal data from users who connected to the fraudulent access points.

Assignment Question: Prepare a Vulnerability Assessment Report for an airport or airline affected by an evil-twin access point. Analyse SSID impersonation, captive-portal authentication, automatic connection, certificate warnings, passenger-data exposure, rogue access-point detection, staff response procedures, and user-verification methods.

10. Network Rail Public Wi-Fi Portal Compromise, 2024

On September 25, 2024, public Wi-Fi services at 19 major United Kingdom railway stations displayed unauthorized offensive content. Reports stated that the Wi-Fi landing page was changed using a legitimate administrator account. The affected services were suspended while the incident was investigated.

Assignment Question: Prepare a Vulnerability Assessment Report examining the authentication and access-control weaknesses that may allow misuse of a legitimate administrator account. Assess privileged-access management, multifactor authentication, captive-portal security, third-party supplier access, logging, change approval, account monitoring, and incident-response procedures.

1. TJX COMPANIES WIRELESS NETWORK BREACH, 2005–2007

1.1 Introduction

TJX Companies experienced a major payment-card data breach between 2005 and 2007. Attackers gained unauthorized access through weaknesses in the company's wireless network. The incident demonstrated the security risks associated with obsolete wireless encryption, inadequate network segmentation, weak monitoring, and insufficient protection of payment information.

1.2 Vulnerability Assessment

Wireless Encryption

TJX used WEP during its transition toward stronger wireless security. WEP is an outdated encryption technology and can be compromised using relatively practical attacks. Sensitive payment-related communication should not depend on obsolete encryption.

Risk: High

Authentication

Weak wireless authentication can allow unauthorized devices to connect to the corporate network. Strong enterprise authentication should be used instead of shared or weak credentials.

Risk: High

Network Segmentation

Wireless users should not have unrestricted access to payment-processing systems. Failure to properly separate wireless networks from sensitive systems increases the impact of a compromise.

Risk: Critical

Monitoring

Insufficient monitoring can allow attackers to remain undetected. Wireless intrusion detection and centralized security logging should be implemented.

Risk: High

Payment-Data Protection

Payment-card information requires strong protection through encryption, access control, tokenization where appropriate, and PCI DSS security controls.

Risk: Critical

1.3 Recommendations

- Replace WEP with WPA2-Enterprise or WPA3-Enterprise.

- Use 802.1X authentication with an appropriate EAP method.
- Implement strong certificate validation.
- Separate wireless networks from payment-processing systems.
- Deploy wireless intrusion detection and prevention systems.
- Encrypt sensitive payment information.
- Apply PCI DSS requirements to cardholder-data environments.
- Maintain centralized security logs and continuous monitoring.
- Conduct regular vulnerability assessments and penetration tests.

1.4 Conclusion

The TJX incident demonstrates that obsolete encryption, weak authentication, inadequate segmentation, and insufficient monitoring can turn a wireless weakness into a major data breach. Modern wireless security and PCI DSS controls could significantly reduce such risks.

2. LOWE'S WIRELESS NETWORK INTRUSION, 2003

2.1 Introduction

Lowe's experienced a wireless network intrusion in 2003 in which attackers compromised a wireless connection and gained access to corporate systems. The incident demonstrated the danger of connecting wireless networks to internal infrastructure without sufficient isolation and access controls.

2.2 Vulnerability Assessment

Authentication

Weak wireless authentication could allow unauthorized users to connect to the network.

Risk: High

Wireless Isolation

The wireless network was insufficiently isolated from internal corporate systems. A compromise of the wireless segment could therefore provide a path toward more sensitive systems.

Risk: Critical

Firewall Controls

Firewalls should restrict communication between wireless networks, corporate networks, and sensitive systems using a deny-by-default approach.

Risk: High

Point-of-Sale Segmentation

Point-of-sale systems should be placed in isolated network segments with access permitted only to required services.

Risk: Critical

Intrusion Detection

Network and wireless intrusion detection can identify suspicious connections, scanning, authentication failures, and abnormal traffic.

Risk: High

Centralized Access Management

Centralized identity and access management provides better control over users, devices, and permissions.

2.3 Recommendations

- Implement WPA2/WPA3-Enterprise.
- Use 802.1X authentication.
- Isolate guest and corporate wireless networks.
- Segment point-of-sale systems using VLANs and firewalls.
- Apply least-privilege access.
- Deploy IDS/IPS and wireless monitoring.
- Use centralized authentication and access management.
- Monitor privileged and administrative activity.

2.4 Conclusion

The Lowe's incident shows that wireless access should never provide unrestricted connectivity to critical corporate systems. Strong authentication, segmentation, firewall controls, and monitoring are essential.

3. FIRESHEEP AND PUBLIC WI-FI SESSION HIJACKING, 2010

3.1 Introduction

Firesheep demonstrated the risks of using public Wi-Fi when websites failed to protect authenticated sessions using HTTPS. Attackers connected to the same network could potentially obtain session cookies and impersonate users.

3.2 Vulnerability Assessment

Open-Wi-Fi Authentication

Open Wi-Fi networks do not provide adequate protection against local network attackers.

Risk: High

Session Cookie Protection

Session cookies transmitted without adequate encryption can be intercepted.

Risk: Critical

Cookies should use:

- Secure attribute
- HttpOnly attribute
- Appropriate SameSite settings
- Short and controlled session lifetimes

HTTPS Enforcement

Websites should use HTTPS throughout the entire authenticated session, not only during login.

Risk: Critical

HSTS

HTTP Strict Transport Security (HSTS) helps browsers use HTTPS instead of insecure HTTP connections.

VPN

A trusted VPN can provide an additional encrypted tunnel when users must operate on untrusted networks.

Wireless Client Isolation

Client isolation prevents wireless users from directly communicating with one another and reduces local attack opportunities.

Security Awareness

Users should understand the risks of connecting to unknown public networks and avoid entering sensitive information over suspicious connections.

3.3 Recommendations

- Enforce HTTPS across the entire website.
- Enable HSTS.
- Protect cookies using Secure and HttpOnly attributes.

- Use appropriate SameSite cookie settings.
- Implement wireless client isolation.
- Encourage VPN use on untrusted networks.
- Educate users about public Wi-Fi risks.
- Monitor suspicious wireless activity.

3.4 Conclusion

The Firesheep incident demonstrated that login-page encryption alone is insufficient. Complete HTTPS protection, secure session management, network isolation, and user awareness are necessary to reduce session-hijacking risks.

4. DARKHOTEL ATTACKS THROUGH HOTEL WI-FI NETWORKS

4.1 Introduction

The DarkHotel campaign demonstrated how attackers could target selected hotel guests through compromised or manipulated hotel networks. Fraudulent software-update prompts were used as a means of delivering malware.

4.2 Vulnerability Assessment

Guest Authentication

Weak guest authentication can make it difficult to identify and control network users.

Captive Portal Security

Captive portals must use secure HTTPS connections and should not request unnecessary sensitive information.

DNS Integrity

DNS manipulation can redirect users toward malicious websites or fraudulent update pages.

Risk: High

Network Segmentation

Guest Wi-Fi must be separated from hotel administration, payment, surveillance, and other critical networks.

Risk: Critical

Third-Party Access

Hotel vendors and service providers should receive only the minimum access required for their responsibilities.

Software Update Verification

Users and organizations should verify software updates through trusted channels and valid digital signatures.

Malware Detection

Endpoint security solutions should detect suspicious downloads, executables, and unusual system activity.

Monitoring

Hotels should monitor wireless infrastructure, authentication events, DNS activity, and privileged administrative systems.

4.3 Recommendations

- Use WPA2/WPA3-Enterprise where appropriate.
- Secure captive portals using HTTPS.
- Protect DNS infrastructure.
- Segment guest and administrative networks.
- Apply least privilege to third-party vendors.
- Use digitally signed software updates.
- Deploy endpoint protection.
- Monitor privileged hotel-network accounts.
- Maintain centralized security logs.

4.4 Conclusion

Hotel Wi-Fi can become a major attack surface because it combines public connectivity, third-party infrastructure, and high-value users. Strong segmentation, secure DNS, verified updates, and continuous monitoring reduce these risks.

5. MARRIOTT WI-FI DEAUTHENTICATION INCIDENT, 2014

5.1 Introduction

The Marriott Wi-Fi incident involved the use of equipment to transmit Wi-Fi deauthentication messages that disrupted guests' personal hotspots. The incident demonstrated the availability risks associated with unprotected wireless management frames.

5.2 Vulnerability Assessment

Availability Risk

Deauthentication attacks can disconnect legitimate wireless clients and disrupt network availability.

Risk: High

Wireless Interference

Unauthorized wireless transmissions can interfere with legitimate networks and devices.

Protected Management Frames

Protected Management Frames (PMF), defined by IEEE 802.11w and incorporated into modern Wi-Fi security, help protect management traffic from certain spoofing-based attacks.

WPA3

WPA3 provides modern wireless security improvements, and PMF is an important part of WPA3 deployments.

Wireless Intrusion Detection

WIDS/WIPS solutions can detect suspicious deauthentication activity and other wireless anomalies.

Acceptable Use Policies

Organizations should clearly define what network activities are permitted and prohibit unauthorized interference with user devices.

Legal Consequences

Unauthorized disruption or interference with wireless communications can result in regulatory, civil, or criminal consequences depending on the jurisdiction and circumstances.

5.3 Recommendations

- Use WPA3 where supported.
- Enable Protected Management Frames.
- Deploy wireless intrusion detection.
- Monitor abnormal deauthentication activity.
- Establish acceptable-use policies.
- Maintain documented wireless-security procedures.
- Investigate and respond to wireless interference incidents.
- Ensure network equipment configuration complies with applicable regulations.

5.4 Conclusion

The incident demonstrates that wireless security must address availability as well as confidentiality. PMF, modern wireless standards, monitoring, and clear policies can reduce the risk of unauthorized wireless disruption.

6. FAKE WI-FI NETWORKS AT THE REPUBLICAN NATIONAL CONVENTION, 2016

6.1 Introduction

A security experiment at the 2016 Republican National Convention demonstrated how users could connect to fake open wireless networks. The experiment showed that users often trust familiar-looking SSIDs without verifying whether the network is legitimate.

6.2 Vulnerability Assessment

SSID Trust

Users may assume that a familiar network name is legitimate.

Risk: High

Automatic Reconnection

Devices configured to automatically reconnect to previously known networks can increase exposure to fake access points.

Captive Portal Authentication

Fake networks may use fraudulent captive portals to collect credentials or personal information.

Evil-Twin Detection

Wireless monitoring should identify access points that imitate legitimate SSIDs.

Certificate Validation

Users should never ignore browser certificate warnings. Websites handling sensitive information should use valid certificates and HTTPS.

VPN Enforcement

VPNs provide an additional layer of protection when users connect through untrusted networks.

Participant Awareness

Users should be trained to verify network names and avoid suspicious portals.

6.3 Recommendations

- Disable automatic connection to unknown networks.

- Use WPA2/WPA3-secured networks where possible.
- Deploy rogue-access-point detection.
- Enforce HTTPS.
- Educate event participants.
- Use VPNs on untrusted networks.
- Provide official network information through trusted channels.
- Monitor wireless activity around event locations.

6.4 Conclusion

Large public events are attractive targets for fake Wi-Fi attacks because many users connect to wireless networks simultaneously. Technical controls and security awareness must work together to reduce the risk.

7. WI-FI ATTACKS AGAINST ANTI-DOPING OFFICIALS, 2016

7.1 Introduction

Anti-doping officials were reportedly targeted through Wi-Fi networks while attending international sporting events. The case demonstrates the security risks faced by organizations whose employees frequently travel and use hotel or event networks.

7.2 Vulnerability Assessment

Public Network Authentication

Public Wi-Fi cannot be assumed to be trustworthy.

Credential Protection

Credentials should never be transmitted through insecure connections. Strong password policies and password managers should be used.

Multifactor Authentication

MFA provides additional protection even when a password is compromised.

Risk Reduction: High

Device Certificates

Managed devices can use digital certificates to establish stronger device identity.

Endpoint Security

Laptops and mobile devices should have current operating-system updates, endpoint protection, disk encryption, and security controls.

VPN Configuration

A properly configured VPN can protect network traffic on untrusted networks.

Travel Security

Employees should receive security training before traveling and should avoid connecting to unknown networks.

Medical Information Protection

Medical and anti-doping information should be treated as highly sensitive and protected using strict access controls and encryption.

7.3 Recommendations

- Implement phishing-resistant MFA where practical.
- Use device certificates for managed devices.
- Enforce VPN use on untrusted networks.
- Apply endpoint detection and response.
- Encrypt sensitive information.
- Use least-privilege access.
- Conduct travel-security awareness training.
- Monitor account activity for unusual locations or behavior.

7.4 Conclusion

Organizations with frequent international travel face increased wireless and credential risks. Strong authentication, managed devices, VPN protection, endpoint security, and strict protection of sensitive information are essential.

8. ATTEMPTED OPCW WI-FI INTRUSION, 2018

8.1 Introduction

In 2018, Dutch authorities disrupted an attempted close-access cyber operation against the Organisation for the Prohibition of Chemical Weapons (OPCW). The incident highlighted the importance of protecting wireless infrastructure from attacks conducted near an organization's physical premises.

8.2 Vulnerability Assessment

Radio-Frequency Exposure

Wireless signals can extend beyond physical building boundaries. Attackers located outside a facility may attempt to interact with wireless infrastructure.

Enterprise Wi-Fi Authentication

Enterprise wireless networks should use strong authentication rather than shared passwords.

802.1X

802.1X provides port-based network access control and can authenticate users or devices before granting network access.

EAP Certificate Validation

Proper certificate validation prevents devices from connecting to fraudulent authentication infrastructure.

Rogue-Device Detection

Wireless monitoring can identify unauthorized access points and suspicious devices.

Wireless Intrusion Prevention

WIPS can detect and respond to suspicious wireless activity according to organizational policies.

Physical Surveillance

Security cameras, access control, and physical monitoring can help identify suspicious activity near wireless infrastructure.

Network Access Control

NAC can verify device identity and security posture before allowing access to internal resources.

8.3 Recommendations

- Use WPA2/WPA3-Enterprise.
- Implement 802.1X authentication.
- Use strong EAP methods and certificate validation.
- Deploy WIDS/WIPS.
- Implement NAC.
- Monitor RF activity around sensitive facilities.
- Maintain physical surveillance.
- Separate sensitive wireless networks from general networks.
- Regularly audit wireless configurations.

8.4 Conclusion

The OPCW case shows that wireless security must consider both cyber and physical threats. Strong authentication, RF monitoring, rogue-device detection, physical security, and NAC provide multiple layers of protection.

9. AUSTRALIAN AIRPORT AND IN-FLIGHT EVIL-TWIN CASE, 2024

9.1 Introduction

The Australian Federal Police charged an individual who allegedly established fake free Wi-Fi access points that imitated legitimate networks at airports and other locations. The case demonstrates the danger of evil-twin networks and the exposure of personal information.

9.2 Vulnerability Assessment

SSID Impersonation

Attackers can create networks using names similar to legitimate networks.

Risk: High

Captive-Portal Authentication

Fake captive portals may request unnecessary personal information or credentials.

Automatic Connection

Devices configured to automatically join known networks may connect to fraudulent access points.

Certificate Warnings

Users should carefully examine browser certificate warnings and never bypass them when accessing sensitive services.

Passenger-Data Exposure

Untrusted Wi-Fi can expose sensitive information if applications or websites do not use strong encryption.

Rogue Access-Point Detection

Airports and airlines should monitor for unauthorized access points using their SSIDs.

Staff Response Procedures

Staff should have clear procedures for reporting and investigating suspected rogue networks.

User Verification

Passengers should receive official network information through airport signage and verified communication channels.

9.3 Recommendations

- Deploy wireless intrusion detection.
- Monitor for unauthorized SSIDs.
- Disable automatic connection to open networks.
- Enforce HTTPS.
- Use VPNs on untrusted networks.
- Educate passengers about evil-twin attacks.
- Provide clearly identified official Wi-Fi information.
- Train staff to report suspicious access points.
- Monitor network infrastructure continuously.

9.4 Conclusion

Evil-twin networks exploit user trust rather than only technical vulnerabilities. Combining wireless monitoring, secure application communication, user awareness, and clear verification procedures can reduce the risk.

10. NETWORK RAIL PUBLIC WI-FI PORTAL COMPROMISE, 2024

10.1 Introduction

On September 25, 2024, public Wi-Fi services at 19 major UK railway stations displayed unauthorized offensive content. Reports indicated that the Wi-Fi landing page was changed using a legitimate administrator account. The incident highlights the risks associated with compromised privileged accounts and third-party Wi-Fi management.

10.2 Vulnerability Assessment

Privileged-Access Management

Administrative accounts should have only the permissions necessary to perform their duties.

Risk: Critical

Multifactor Authentication

MFA should be required for administrator accounts to reduce the risk of password-only compromise.

Risk: Critical

Captive-Portal Security

The portal administration system should be separated from public Wi-Fi traffic and protected using strong access controls.

Third-Party Supplier Access

Third-party suppliers should use controlled, individually assigned accounts with limited privileges and monitored access.

Logging

Administrative actions, authentication events, configuration changes, and portal modifications should be logged centrally.

Change Approval

Important configuration changes should require authorization and follow a formal change-management process.

Account Monitoring

Privileged accounts should be monitored for unusual login locations, access times, failed authentication, and unexpected administrative actions.

Incident Response

Organizations should maintain procedures for isolating affected systems, disabling compromised accounts, preserving evidence, investigating the incident, and restoring services securely.

10.3 Recommendations

- Implement phishing-resistant MFA for privileged accounts.
- Use privileged-access management solutions.
- Apply least-privilege principles.
- Use separate administrative accounts.
- Monitor administrator activity continuously.
- Implement centralized security logging.
- Require approval for significant configuration changes.
- Review third-party supplier access regularly.
- Conduct periodic access reviews.
- Maintain an incident-response plan.
- Segment captive-portal administration from public Wi-Fi networks.

10.4 Conclusion

The Network Rail incident demonstrates that legitimate administrative accounts can become a major security weakness when they are not adequately protected. Strong MFA, privileged-

access management, logging, change control, supplier management, and incident response can significantly reduce this risk.

OVERALL CONCLUSION

The ten case studies demonstrate that wireless networks can expose organizations to confidentiality, integrity, and availability risks. Common weaknesses include outdated encryption, weak authentication, poor network segmentation, insecure captive portals, rogue access points, inadequate monitoring, compromised administrative accounts, and insufficient user awareness.

A strong wireless-security architecture should therefore use **WPA2-Enterprise or WPA3-Enterprise, 802.1X authentication, Protected Management Frames, network segmentation, firewalls, wireless intrusion detection and prevention, secure HTTPS, MFA, endpoint protection, centralized logging, privileged-access management, and regular security assessments.**

Security should also follow the principle of **defense in depth**, where multiple independent controls protect critical systems. Combining technical controls with employee training, access-management policies, incident-response procedures, and compliance requirements provides stronger protection against wireless attacks.

REFERENCES

1. PCI Security Standards Council – PCI DSS.
2. NIST – Wireless Network Security Guidelines.
3. NIST Special Publication 800-153 – Guidelines for Securing Wireless Local Area Networks.
4. Wi-Fi Alliance – WPA2 and WPA3 Security Standards.
5. OWASP – Web Application Security and Transport Layer Security Guidance.
6. IEEE 802.11 Wireless LAN Standards.
7. ISO/IEC 27001 – Information Security Management Systems.
8. ISO/IEC 27002 – Information Security Controls.
9. U.S. Federal Communications Commission – Wireless Network Security and Enforcement Materials.
10. Australian Federal Police – Cybercrime and Public Wi-Fi Security Information.